

Vulnerability Assessment & Penetration Testing Verification Report

Target: https://rezilyens.com (IP: 129.146.168.150)

Date: April 28, 2025

Auditor: RAVINDHAR V, Cyber Security Engineer

Executive Summary

This document summarizes the verification of vulnerability findings identified on https://rezilyens.com (129.146.168.150) following the original VAPT conducted in April 2025. Each finding was carefully retested using browser-based methods, command-line tools (e.g., curl), and third-party services (e.g., securityheaders.com).

Findings Overview:

- Unresolved Issues:** Several issues remain unresolved, including missing HTTP security headers, server information leakage, outdated WordPress version, and user enumeration vulnerabilities.
- Remediated Issues:** Some findings have been successfully addressed, such as XML-RPC access now being blocked.
- Improved Status:** The status of certain findings has improved, with PHP error disclosure no longer observed during testing.

System Information

Component	Details
CMS	WordPress 6.7.1
Web Server	Nginx 1.26.3
Programming Language	PHP 8.3.16
Database	MySQL (inferred)
CDN	Cloudflare, cdnjs
Theme	rezilyens-child (version 1.2)
JS Libraries	jQuery, jQuery Migrate, Underscore.js, Slick, Modernizr, FancyBox
UI Framework	Bootstrap
Font Scripts	Google Font API, Font Awesome
Operating System	Linux (inferred)
Hosting	OCI (Oracle Cloud Infrastructure)
IP Address	129.146.168.150
Open Ports	80, 443

Verified Findings Summary

ID	Vulnerability	Severity	Status	Remediation Needed
1	PHP Error Disclosure	Critical	Not Observed	Periodic checks
2	Missing HTTP Security Headers	High	Confirmed	Yes
4	robots.txt Disclosure	Medium	Confirmed	Optional
5	Exposed WordPress readme.html	Medium	Confirmed	Yes
6	Server/Version Disclosure Headers	Medium	Confirmed	Yes
7	External WP-Cron Access	Medium	Confirmed	Yes
8	HSTS Missing	Low/High	Confirmed	Yes
9	Outdated WordPress Version	High	Confirmed	Yes
10	User Enumeration	Medium	Confirmed	Yes
11	Theme Information Disclosure	Low	Confirmed	Optional

Detailed Findings

1. PHP Error Disclosure

Severity: Critical

Status: Not Observed

Original Issue:

Sensitive PHP errors were displayed, revealing internal paths like '/var/www/html/wp-content/themes/rezilyens-child/index.php'.

Current Status:

No errors observed during verification.

XML-RPC: GoBuster

/xmlrpc.php (Status: 200)

```
/wp-admin      [36m (Status: 301) [0m [Size: 169] [34m [--> https://rezilyens.com/wp-admin/] [0m
/wp-content    [36m (Status: 301) [0m [Size: 169] [34m [--> https://rezilyens.com/wp-content/] [0m
/wp-includes   [36m (Status: 301) [0m [Size: 169] [34m [--> https://rezilyens.com/wp-includes/] [0m
/xmlrpc.php    [32m (Status: 200) [0m [Size: 216]
```

Recommendation:

Maintain display_errors=Off in php.ini, ensure errors are logged securely server-side, monitor periodically.

2. Missing HTTP Security Headers

Severity: High

Status: Confirmed

Evidence:

```
ravindhav@Mac ~ % curl -I https://rezilyens.com
HTTP/1.1 200 OK
Server: nginx/1.26.3
Date: Mon, 28 Apr 2025 05:16:33 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/8.3.16
Link: <https://rezilyens.com/wp-json/>; rel="https://api.w.org/"
Link: <https://rezilyens.com/wp-json/wp/v2/pages/5>; rel="alternate"; title="JSON"; type="application/json"
Link: <https://rezilyens.com/>; rel=shortlink
```

Missing Headers:

- Strict-Transport-Security
- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

Recommendation:

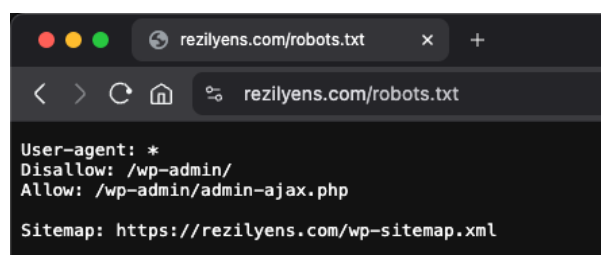
Add these headers via web server (Nginx) configuration to enhance security against clickjacking, XSS, MIME-sniffing, and enforce HTTPS.

4. robots.txt Disclosure

Severity: Medium

Status: Confirmed

Evidence:



```
rezilyens.com/robots.txt
User-agent: *
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php
Sitemap: https://rezilyens.com/wp-sitemap.xml
```

Assessment:

Minor exposure, standard for WordPress but reveals administrative paths. Consider removing platform-specific directives if higher security is desired, though obscurity isn't a primary defense.

Recommendation:

No immediate action required, but review if sensitive paths should be further obfuscated (Optional).

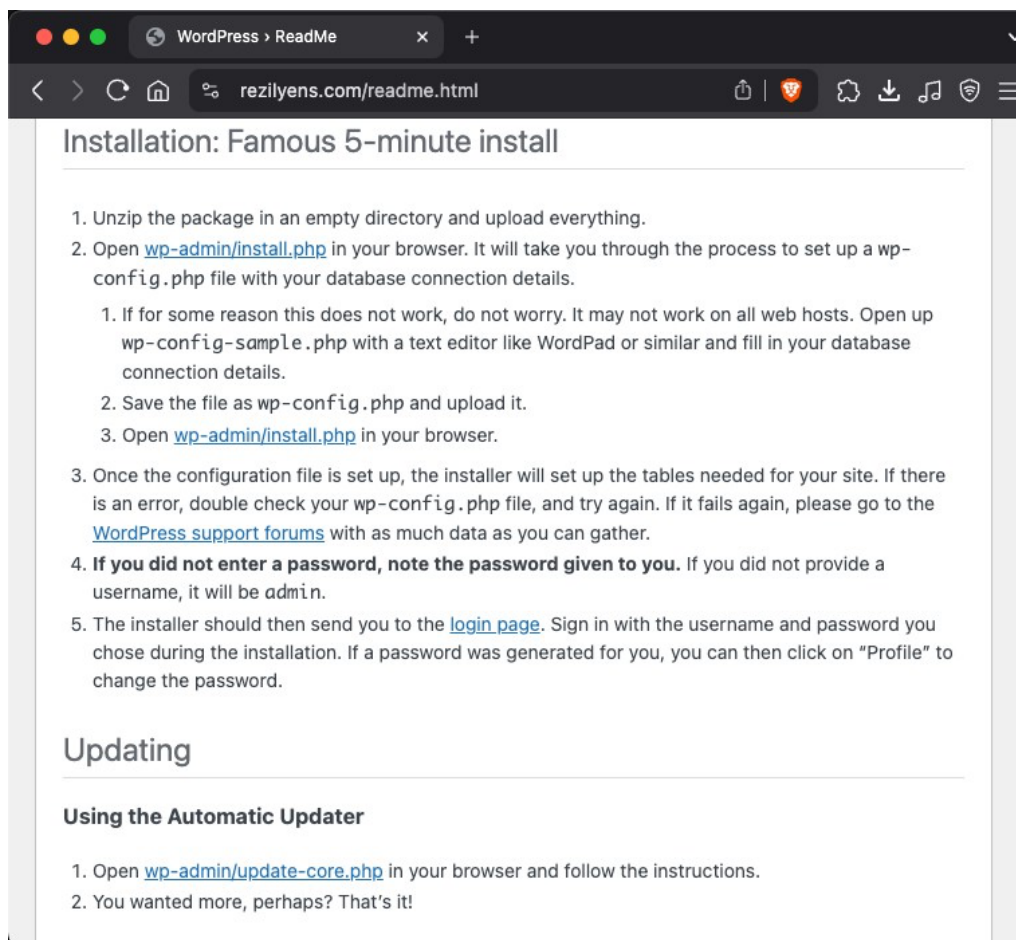
5. Exposed WordPress readme.html

Severity: Medium

Status: Confirmed

Evidence:

```
[ravindharv@Mac ~ % curl -I https://rezilyens.com/readme.html
HTTP/1.1 200 OK
Server: nginx/1.26.3
Date: Mon, 28 Apr 2025 06:36:48 GMT
Content-Type: text/html
Content-Length: 7409
Last-Modified: Tue, 18 Jun 2024 11:59:14 GMT
Connection: keep-alive
ETag: "66717692-1cf1"
Accept-Ranges: bytes
```



Assessment:

Provides attackers with information about the CMS and potentially version details, aids reconnaissance.

Recommendation:

Delete or restrict access to readme.html via web server configuration.

6. Server Technology/Version Disclosure

Severity: Medium

Status: Confirmed

Evidence:

```
ravindharv@Mac ~ % curl -I https://rezilyens.com
HTTP/1.1 200 OK
Server: nginx/1.26.3
Date: Mon, 28 Apr 2025 06:38:33 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/8.3.16
Link: <https://rezilyens.com/wp-json/>; rel="https://api.w.org/"
Link: <https://rezilyens.com/wp-json/wp/v2/pages/5>; rel="alternate"; title="JSON"; type="application/json"
Link: <https://rezilyens.com/>; rel=shortlink
```

Assessment:

Exposes specific software versions, aiding attackers in finding version-specific vulnerabilities.

Recommendation:

Configure Nginx (`server_tokens off;`) and PHP (`expose_php = Off` in `php.ini`) to hide version information.

7. External WP-Cron Access

Severity: Medium

Status: Confirmed

Evidence:

```
ravindharv@Mac ~ % curl -I https://rezilyens.com/wp-cron.php
HTTP/1.1 200 OK
Server: nginx/1.26.3
Date: Mon, 28 Apr 2025 06:39:24 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/8.3.16
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0
```

Assessment:

Default WordPress behavior, but can be abused for DDoS attacks or if cron tasks have vulnerabilities.

Recommendation:

Disable default WP-Cron in `wp-config.php` (`define('DISABLE_WP_CRON', true);`). Configure a system cron job (e.g., via `crontab`) to trigger `wp-cron.php` locally at regular intervals. Restrict direct web access to `wp-cron.php` if possible (e.g., via web server rules).

8. HSTS Missing

Severity: Low/High

Status: Confirmed

Evidence:

As shown in the headers output above, the Strict-Transport-Security HTTP header is not sent by the server over HTTPS.

Assessment:

Leaves users vulnerable to protocol downgrade attacks and cookie hijacking over insecure connections.

Recommendation:

Implement the HSTS header in Nginx configuration (`add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;`). Ensure the site is fully functional over HTTPS before enabling, especially `includeSubDomains` and `preload`.

9. Outdated WordPress Version

Severity: High

Status: Confirmed

Evidence:

```
# wpscan --url https://rezilyens.com
[+] WordPress version 6.7.1 identified (Released on 2024-11-21)
[!] 2 vulnerabilities identified in the version
```

Assessment:

Using outdated software significantly increases risk as known vulnerabilities may exist and be unpatched.

Recommendation:

Update WordPress core to the latest stable version immediately. Regularly check for and apply updates to WordPress core, themes, and plugins.

10. User Enumeration

Severity: Medium

Status: Confirmed

Evidence:

```
# wpscan --url https://rezilyens.com --enumerate u
[+] Enumerating Users
[+] Identified the following 5 user/s:
| Username: admin
| Detected By: Author Posts (Passive Detection)
|
| Username: wordcamp
| Detected By: oEmbed API (Passive Detection)
| Confirmed By: Author ID Brute Forcing (Aggressive Detection)
|
| Username: Rez
```

```
| Detected By: REST API - Author IDs (Passive Detection)
|
| Username: test
| Detected By: RSS Feed (Passive Detection)
|
| Username: adminbackup
| Detected By: Author ID Brute Forcing (Aggressive Detection)
```

Assessment:

Disclosed usernames simplify brute-force login attempts.

Recommendation:

Implement measures to prevent username enumeration (e.g., security plugins, web server rules disabling author scans, REST API hardening). Use strong, unique passwords and enable multi-factor authentication (MFA).

11. Theme Information Disclosure

Severity: Low

Status: Confirmed

Evidence:

```
# wpscan --url https://rezilyens.com --enumerate t
[+] rezilyens-child
| Location: https://rezilyens.com/wp-content/themes/rezilyens-child/
| Style URL: https://rezilyens.com/wp-content/themes/rezilyens-
child/style.css?ver=1.2
| Style Name: Rezilyens Child
| Style URI: https://rezilyens.com/
| Description: This is a child theme for Rezilyens theme
| Version: 1.2
```

Assessment:

Minor information disclosure, could aid targeted attacks if theme vulnerabilities exist.

Recommendation:

Ensure the theme (and parent theme) are kept up-to-date. Consider removing version numbers from stylesheet URLs if possible, although this provides limited security benefit (Optional).

Priority Recommendations

High Priority Actions

1. Add Missing HTTP Security Headers

- Configure Nginx with the following headers:

```
add_header Strict-Transport-Security "max-age=31536000;  
includeSubDomains; preload" always;  
add_header X-Frame-Options "SAMEORIGIN" always;  
add_header X-Content-Type-Options "nosniff" always;  
add_header Referrer-Policy "strict-origin-when-cross-origin" always;  
add_header Permissions-Policy "geolocation=(), microphone=()" always;
```

2. Create and Apply a Tailored Content-Security-Policy

- Define allowed sources for scripts, styles, images, etc., to mitigate XSS
- Requires careful planning based on site content and functionality

3. Update WordPress Core

- Upgrade immediately from version 6.7.1 to the latest stable version to patch known vulnerabilities

4. Hide Server Tokens and PHP Version

- Configure `server_tokens off;` in `nginx.conf`
- Set `expose_php = Off` in `php.ini`

5. Harden WordPress Cron Management

- Disable WP-Cron via `wp-config.php` (`define('DISABLE_WP_CRON', true);`)
- Set up a system cron job instead

6. Prevent User Enumeration

- Use security plugins or server rules to block common enumeration vectors
- Disable author scans if not needed
- Ensure strong passwords and enable MFA

7. Remove or Restrict Access to `readme.html`

- Delete the file or block access via web server rules

8. Maintain PHP Error Suppression and Secure Logging

- Ensure `display_errors=Off`
- Configure PHP to log errors to a secure, non-web-accessible file

Optional Actions

1. Reconsider `robots.txt` Disclosure

- Evaluate if exposing `/wp-admin/` path presents an unacceptable risk
- Consider removing WordPress-specific rules, though standard practice is generally acceptable

2. Harden Theme Information Disclosure

- Ensure themes are updated
- Optionally remove version parameters from CSS files (security impact is low)

Testing Methodology

The verification was conducted using the following tools and methods:

- **Wappalyzer:** Identified technologies including WordPress 6.7.1, Nginx 1.26.3, PHP 8.3.16, jQuery, Cloudflare CDN, Font Awesome, Bootstrap, etc.
- **Directory Brute-Force:** Mapped directory structure, confirmed standard WordPress paths, and 403 responses on sensitive files like .htaccess.
- **WPScan:** Confirmed WordPress 6.7.1 (outdated), theme rezilyens-child 1.2, PHP 8.3.16, Nginx 1.26.3, exposed readme.html, enabled WP-Cron, and enumerated users (admin, wordcamp, Rez, test, adminbackup).
- **Nikto:** Detected missing security headers (X-Frame-Options, HSTS, X-Content-Type-Options), PHP version, and x-redirect-by header.
- **Nmap:** Confirmed open ports 80 (HTTP) and 443 (HTTPS) running Nginx 1.26.3.
- **DNS Lookups** (nslookup, dig): Resolved rezilyens.com to 129.146.168.150.
- **curl:** Used to verify headers and file accessibility (e.g., readme.html, wp-cron.php). Confirmed server/PHP versions.
- **securityheaders.com:** Used to verify missing HTTP security headers.

Conclusion

The verification confirmed several critical and high-severity unresolved vulnerabilities, including missing security headers, information disclosure (server versions, WordPress paths/files, usernames), an outdated WordPress core, and default configurations allowing WP-Cron access and user enumeration.

Of particular concern is the successful enumeration of admin users (admin, adminbackup) along with standard users (wordcamp, Rez, test) through multiple detection methods, which significantly increases the risk of targeted brute-force attacks. The outdated WordPress core (version 6.7.1) contains known vulnerabilities that should be addressed immediately.

Priority must be given to implementing security headers, immediately updating WordPress, hardening configurations (server tokens, WP-Cron, PHP errors), preventing user enumeration, and restricting unnecessary file access.

Continued monitoring and periodic security assessments are essential to maintain strong defenses against evolving threats.

Contact Information

RAVINDHAR V

Cyber Security Engineer

Email: ravindhar.upm@gmail.com

LinkedIn: <https://www.linkedin.com/in/ravindhar-cy/>